

Documentation-Driven Threat Analysis

Documentation and Base Analysis Authoring Guide

Revision 4 - pre-holdout frozen documentation protocol

Metodo operativo per documentare il minimum sufficient governed meaning e consegnarlo alla
Base Analysis

Stato. R25 DOCUMENTATION-METHOD FREEZE / PRE-HOLDOUT AUTHORIZING PROTOCOL.

Project authority. FACIAL-ACCESS-GOV-R2.

Facial Access BA evidence. FACIAL-ACCESS-BA-R24-R1: complete case BA / post-BA regression PASS; integrated BA6 acceptance OPEN.

Pinned source revision. 8af2257a1df94fa5a83d4853ed0a1eb4d020c429.

Questa guida congela il protocollo documentale pre-holdout. Non sostituisce i documenti governati del progetto e non usa BA6 come risultato già chiuso. La Base Analysis resta una fase downstream separata.

Indice

1	Scopo della guida	1
1.1	Il livello di dettaglio non è fissato globalmente	1
2	R25 pre-holdout freeze	1
2.1	Anti-contamination rule	2
2.2	Status delle regole	2
3	Authority prima della scrittura	2
4	Problem framing	3
5	MacroRequirement	3
5.1	Semantic-sufficiency gate	3
6	Decision	4
7	Functional Requirement	4
7.1	Non anticipare la BA	4
7.2	Binding contestuale	5
8	Requirement split e unità coerente	5
9	Specialized Requirement	5
10	Security Requirement	6
10.1	Proprietà non significa meccanismo	6
10.2	NOT SPECIFIED può essere corretto	6
11	Cross-MR semantics	6
12	Consumed service boundary	7
13	Decisioni con condizioni congiunte	7
14	Documentation gaps e clarification	7
15	Canonical terminology	8
16	Promotion gate	8
17	Handoff alla Base Analysis	8
18	Facial Access - esempio end-to-end	9
19	Checklist pratica di authoring	9

20 Cosa non deve fare la documentazione	10
21 Stato corrente e prossimo uso	10

1 Scopo della guida

Questa guida spiega come produrre documentazione governata che rimanga leggibile per le persone, stabile nel tempo e sufficientemente precisa per una successiva Base Analysis senza anticipare dettagli di implementazione non ancora decisi.

Principio centrale

La documentazione deve governare il **minimum sufficient governed meaning**: abbastanza semantica per distinguere responsabilità, decisioni, comportamenti, condizioni e proprietà materialmente rilevanti, ma non più dettaglio di quello giustificato dal progetto.

La completezza documentale non coincide con la descrizione esaustiva del sistema. Una baseline può essere adeguata anche quando alcuni aspetti restano NOTSPECIFIED, purché l'assenza non venga mascherata e non impedisca il significato necessario allo scope corrente.

1.1 Il livello di dettaglio non è fissato globalmente

DDTA non impone un livello uniforme come “architettura”, “componente”, “interfaccia” o “protocollo”. Il criterio è adattivo:

```
documentazione governata
  -> domanda semantica o di sicurezza
  -> l'evidenza e' sufficiente?
      YES -> stop
      NO  -> gap / NOT SPECIFIED / ulteriore review
```

La domanda di arresto è:

Stopping criterion

Abbiamo abbastanza semantica per formulare la proprietà o la domanda rilevante e dire, con evidenza documentale, se è soddisfatta, violata oppure non specificata?

2 R25 pre-holdout freeze

Questa revisione R4 è il protocollo documentale congelato che verrà usato per il nuovo caso di validazione strutturalmente diverso.

Freeze rule

Il nuovo holdout non è ancora selezionato né scritto. Di conseguenza, nessuna regola di questa guida è stata adattata al dominio futuro.

Dopo il freeze, il nuovo caso può:

- essere rappresentato correttamente dal metodo corrente;
- esporre una insufficienza del contratto documentale;
- esporre una distinzione non governata e quindi produrre NOTSPECIFIED;
- richiedere una riapertura solo attraverso un counterexample concreto.

2.1 Anti-contamination rule

Durante l'autoring del holdout non si consulta BA2 per decidere quali significati di progetto introdurre.

Sono vietate motivazioni come:

```
aggiungiamo un transfer per testare transfer
aggiungiamo uno state change per testare transition
creiamo una proprieta' per facilitare decisionRule
scegliamo una struttura perche' la BA la rappresenta bene
```

La documentazione deve essere guidata dal problema e dalle decisioni del progetto.

2.2 Status delle regole

La guida distingue:

```
FROZEN PRE-HOLDOUT RULE
  regola usata per il nuovo caso

CASE EVIDENCE
  esempio Facial Access che illustra la regola

NOT SPECIFIED / OPEN
  significato non governato o domanda non ancora chiusa
```

Il freeze non implica completezza universale del metodo. Un nuovo counterexample puo' riaprire il minimo owning layer.

3 Authority prima della scrittura

La cronologia non determina authority.

Prima di creare, revisionare o usare un documento:

1. identificare la baseline governata corrente;
2. distinguere artifact correnti, candidate, working e superseded;
3. preservare la provenance delle revisioni storiche;
4. evitare che BA, tool o analisi downstream diventino project authority.

```
project documentation
  = project authority

Base Analysis
  = analytical representation

threat method / test / projection
  = downstream consumer
```

Un finding downstream può proporre una clarification o una correzione, ma la project truth cambia soltanto attraverso review e aggiornamento della documentazione governata.

4 Problem framing

La documentazione inizia dalla responsabilità del progetto, non dalla tecnologia disponibile.

DA EVITARE

Il sistema usa una telecamera IP Ethernet,
un PC locale e un modello facciale per aprire il varco.

Questa frase incorpora già soluzione, placement, mezzo e attuazione fisica.

PREFERIBILE

Il progetto controlla un tentativo di accesso,
distingue la persona presente,
lo stato di autorizzazione rilevante
e la decisione sul singolo tentativo.

Il framing è una disciplina di metodo. Non richiede necessariamente un nuovo tipo di documento.

5 MacroRequirement

Un MacroRequirement governa una responsabilità stabile del problema.

Deve rispondere almeno a:

- che cosa è responsabilità del branch;
- quale significato o risultato macro produce/contribuisce;
- quali responsabilità importanti sono fuori scope;
- quali stakeholder sono materialmente interessati;
- quali dipendenze macro esistono senza confondere dependency e containment.

Corpo consigliato:

Title	
Intent	
Context	
Stakeholders	
Scope	
Assumptions / Constraints	[solo se branch-wide]
dependsOn	[solo quando genuino]

5.1 Semantic-sufficiency gate

Prima di scendere a Decision o Functional Requirement, verificare che l'MR abbia un solo significato stabile.

MR-0003

La formulazione corrente chiarisce che, quando la responsabilità inizia, la persona è presente ma la specifica **GovernedIdentity** corrispondente non è ancora determinata. Questa frase elimina la lettura alternativa in cui una identità specifica sarebbe già preselezionata e il sistema dovrebbe soltanto verificarla.

6 Decision

Una Decision governa una scelta progettuale materialmente rilevante che specializza una responsabilità più stabile.

Una Decision dovrebbe esplicitare:

Context
Decision
Consequences

Una scelta merita una Decision autonoma quando:

- può cambiare senza cambiare la responsabilità macro;
- modifica placement, boundary, strategia o altro significato riusabile;
- è necessario distinguerla da alternative progettuali reali;
- il cambiamento può richiedere revalidazione downstream.

D-3.1, D-3.4, D-3.5, D-3.6

Nel caso Facial Access sono Decision distinte:

- riconoscimento facciale come strategia;
- separazione CameraSubsystem / RecognitionProcessor;
- consumo di un servizio di connettività non posseduto dal progetto;
- Ethernet cablata come mezzo corrente dell'interazione.

Separarle evita che “facial recognition”, “camera”, “servizio” ed “Ethernet” diventino un unico commitment indivisibile.

7 Functional Requirement

Un Functional Requirement governa un comportamento operativo verificabile derivato da una responsabilità/Decision.

Una buona formulazione identifica:

- quando il comportamento è richiesto;
- chi ne possiede la responsabilità funzionale;
- il significato di input/output o stato coinvolto;
- il binding contestuale necessario;
- ciò che il FR deliberatamente non governa.

7.1 Non anticipare la BA

La documentazione deve governare il significato del progetto, non scegliere un operatore BA per comodità.

FR-3.4.1 - acquire

La fonte governa che `CameraSubsystem` acquisisca una nuova `RecognitionCapture` quando la `IdentityDeterminationRequest` la richiede.

La fonte non decide se “acquire” debba essere modellato come:

```
create
observe
produce
combination
```

Questa under-specification è intenzionale e corretta.

7.2 Binding contestuale

Quando due significati devono rimanere associati alla stessa richiesta, identità, tentativo o valutazione, il binding appartiene alla semantica del FR se è necessario per evitare un risultato materialmente diverso.

Nel caso Facial Access:

```
RecognitionCapture
  <-> IdentityDeterminationRequest
```

è parte dell’obbligo di acquisizione e deve essere preservato nel delivery.

8 Requirement split e unità coerente

Non dividere automaticamente un requisito in una riga per verbo. Dividere quando esistono obblighi con:

- semantic owner diverso;
- failure mode materialmente distinto;
- lifecycle/review indipendente;
- diversa specializzazione di sicurezza;
- diversa possibilità di change/revalidation.

Evitare anche l’estremo opposto: un FR che contiene strategia, algoritmo, trasporto, security mechanism e policy organizzativa in un unico testo.

9 Specialized Requirement

Uno Specialized Requirement è giustificato quando una proprietà più specifica deve essere governata autonomamente rispetto al FR parent.

Non deve essere creato solo per riempire una gerarchia.

DG-FA-002

La review Facial Access non ha trovato evidenza sufficiente per introdurre un requisito quantitativo di “capture quality”.

Il significato necessario è stato governato nell’esito:

```
SUCCESS
```


NEGATIVE
INCONCLUSIVE

Non sono stati inventati score, confidence, threshold o ranking.

10 Security Requirement

Un Security Requirement deve specializzare un comportamento o significato governato e mantenere esplicito lo scope della proprietà.

Nel corpus Facial Access:

```
FR-3.4.2 RecognitionCaptureDelivery
  -> Confidentiality
  -> Integrity
  -> AuthorizedProvenance
```

Queste proprietà non vengono propagate automaticamente a tutto il sistema.

10.1 Proprietà non significa meccanismo

DA EVITARE

```
Confidentiality -> TLS
Integrity       -> signature
Provenance      -> certificate
```

Nessuna di queste equivalenze è autorizzata se il progetto non governa il meccanismo.

10.2 NOT SPECIFIED può essere corretto

Il corpus governa le proprietà C/I/AuthorizedProvenance ma non la base completa di autorizzazione per:

- chi possa conoscere il contenuto della capture (AUTH-C);
- quale evidenza renda una origine autorizzata per una specifica request (AUTH-P).

Questi significati restano NOTSPECIFIED e non bloccano la baseline dimostrativa corrente.

11 Cross-MR semantics

Quando un risultato attraversa responsabilità diverse, il downstream consumer deve essere governato per responsabilità, non inventato come componente tecnico.

Nel caso corrente:

```
MR-0003
  -> IdentityDeterminationOutcome
  -> SUCCESS makes GovernedIdentity X available

MR-0002
  -> AccessAuthorizationState concerning GovernedIdentity X

MR-0001
```

```
-> uses both meanings
-> AccessDecision
```

L'identità usata per l'autorizzazione deve essere la stessa resa disponibile dalla determinazione riuscita.

12 Consumed service boundary

Un servizio consumato non diventa automaticamente responsabilità del progetto.

D-3.5

La realizzazione corrente consuma **ConnectivityService**. Il progetto non possiede né gestisce l'infrastruttura sottostante.

Quindi:

```
consumption != ownership
requirement != provider guarantee
wired medium != hidden end-to-end topology
```

Se una proprietà richiesta al servizio non è garantita da evidenza governata, il risultato è una *assurance/coverage question*, non una nuova *project truth* inventata.

13 Decisioni con condizioni congiunte

Una policy decisionale deve governare abbastanza semantica da distinguere condizioni necessarie, ramo positivo e rami non consentiti.

D-1.1 / FR-1.1

```
SUCCESS
AND required authorization condition satisfied
    for the same GovernedIdentity
    -> AccessDecision MUST ALLOW

NEGATIVE
    -> MUST NOT ALLOW

INCONCLUSIVE
    -> MUST NOT ALLOW

SUCCESS
AND required authorization condition not satisfied
    -> MUST NOT ALLOW
```

La documentazione non è obbligata a introdurre un campo **authorized=TRUE**. Se quel vocabolario non esiste, non deve essere creato per facilitare la BA.

14 Documentation gaps e clarification

Un gap è una diagnosi, non un requisito automatico.

Classificazioni utili:

```
missing governed meaning  
conflicting governed meaning  
ambiguous semantic owner  
consumer evidence insufficient  
analysis-relevant NOT SPECIFIED  
deferred outside current scope
```

Il ciclo corretto è:

```
analysis / BA question  
-> diagnostic  
-> semantic-owner review  
-> project-document change only if justified  
-> rebuild BA
```

15 Canonical terminology

I riferimenti semanticamente operativi devono avere identità/nome canonico controllato.

Una frase umana può dire “la camera invia la capture”, ma questo non crea automaticamente alias normativi come:

```
send  
deliver  
push  
tx
```

per un eventuale operatore BA.

Lo stesso vale per nomi di referent e valori controllati.

16 Promotion gate

Una baseline documentale è pronta per promotion quando:

- il semantic owner dei significati materiali è stabilito;
- le cross-responsibility dependencies necessarie sono governate;
- i gap bloccanti sono risolti o esplicitamente esclusi;
- i NOTSPECIFIED non bloccanti sono preservati;
- una regression semantica completa non rileva contraddizioni non gestite;
- la governance autorizza esplicitamente l’uso come source per BA.

17 Handoff alla Base Analysis

Il passaggio alla BA non significa “tradurre ogni frase”.

L’handoff fornisce:

- baseline authority key;
- pinned source revision;
- source set;

- termini/referent governati;
- relazioni/condizioni materialmente necessarie;
- diagnostics e NOTSPECIFIED;
- change/revalidation context quando rilevante.

La BA applica poi il proprio criterio minimo e il contratto pre-holdout corrente (BA0–BA5 con BA2 R3). BA6 resta il successivo gate di validazione integrata.

18 Facial Access - esempio end-to-end

La documentazione corrente dell'esempio è:

```
FACIAL-ACCESS-GOV-R2
CURRENT_GOVERNED

MR-0001 Access Control
MR-0002 Access Authorization
MR-0003 Identity Determination
```

I passaggi principali sono:

1. MR-0003 chiarisce che l'identità specifica non è preselezionata.
2. D-3.1 sceglie riconoscimento facciale.
3. D-3.2 governa SUCCESS/NEGATIVE/INCONCLUSIVE.
4. D-3.4 separa acquisizione e riconoscimento.
5. FR-3.4.1 governa acquire senza specificare snapshot/streaming.
6. FR-3.4.2 governa delivery e request binding.
7. D-3.5 governa servizio consumato.
8. D-3.6 governa Ethernet cablata sul delivery corrente.
9. SEC-3.4.2-C/I/P specializzano quel delivery.
10. MR-0002 governa stato di autorizzazione riferito a GovernedImage senza enum interno.
11. D-1.1/FR-1.1 governano la policy congiuntiva e il ramo positivo.
12. la semantic regression chiude il corpus.
13. la governance promuove FACIAL-ACCESS-GOV-R2.
14. la BA viene costruita e regressata separatamente.

19 Checklist pratica di authoring

Prima di chiudere una revisione chiedere:

1. Sto governando un problema/responsabilità o una soluzione prematura?
2. Il semantic owner è unico e chiaro?
3. Ho separato Decision e comportamento funzionale?
4. Ho introdotto dettagli che il progetto non ha deciso?

5. Un binding di request/identity/context è materialmente necessario?
6. Una proprietà è scoped al comportamento corretto?
7. Sto confondendo proprietà di sicurezza e meccanismo?
8. Sto trasformando un gap in requisito senza review?
9. Un NOTSPECIFIED può rimanere esplicito?
10. Un downstream consumer potrebbe ottenere due letture materialmente diverse?
11. Il cambiamento di una Decision può essere revalidato senza riscrivere l'MR?
12. La baseline è davvero autorizzata per handoff BA?

20 Cosa non deve fare la documentazione

La documentazione DDTA non deve:

- anticipare STRIDE/STRIDE-AI;
- creare un DFD solo perché un threat tool lo richiede;
- descrivere provider hop non governati;
- introdurre protocolli e security mechanisms per default;
- scegliere operatori BA;
- creare sinonimi normativi non registrati;
- nascondere ambiguità con wording generico;
- trasformare automaticamente findings in project truth.

21 Stato corrente e prossimo uso

La baseline governata dell'esempio è **FACIAL-ACCESS-GOV-R2**.

La Base Analysis **FACIAL-ACCESS-BA-R24-R1** è conservata come complete case BA con post-BA regression **PASS**. L'accettazione integrata BA6 resta **OPEN**.

Questa guida R4 è la **documentation-method baseline congelata pre-holdout**.

Il suo prossimo uso non è la scrittura della tesi né la selezione di una soluzione tecnica: è l'authoring del nuovo caso di validazione, ma soltanto dopo il completamento delle restanti fasi R25 pre-holdout.

Prima del nuovo caso devono ancora essere congelati:

- il contratto Base Analysis pre-holdout;
- l'evidenza thesis-ready;
- i pointer repository/tesi;
- il checkpoint immutabile **PRE-HOLDOUT**.

ThreatForge resta differito alla fase post-stabilizzazione come reference implementation / experimental harness.

La valutazione STRIDE/STRIDE-AI resta successiva alla stabilizzazione metodologica e alla reimplementazione di ThreatForge.